

FR.002 — Otorisasi Akses Berbasis Role (Role-Based Access Control)

Proyek: Aplikasi Mini Bank

1. Pendahuluan

Dokumen ini mendefinisikan kebutuhan fungsional **FR.002 — Otorisasi Akses Berbasis Role** pada Aplikasi Mini Bank. Fitur ini memastikan pengguna hanya dapat melihat menu dan mengakses halaman/endpoint sesuai kewenangannya (CS/Teller/Supervisor/Admin), termasuk pencegahan akses ilegal melalui manipulasi URL langsung.

2. Deskripsi Fungsional

Sistem harus memiliki kemampuan untuk:

- Mengidentifikasi *role* pengguna secara akurat setelah proses login.
- Menampilkan menu navigasi yang relevan hanya untuk *role* tertentu (*UI-level restriction*).
- Memblokir akses ke URL atau *endpoint* API yang tidak sesuai dengan *role* pengguna (*server-side enforcement*).
- Memberikan respon penolakan yang standar dan jelas (HTTP 403 atau redirect ke halaman khusus "Akses Ditolak").

3. User Stories

US-AUTHZ-001

Sebagai Pengguna Sistem, **saya ingin** hanya melihat menu sesuai role saya, **sehingga** saya tidak bingung dan tidak mencoba fitur yang bukan kewenangan saya.

Acceptance Criteria:

- Setelah login, menu yang tampil hanya menu milik role pengguna.
- Menu milik role lain tidak boleh muncul di bilah navigasi (sidebar/navbar).

US-AUTHZ-002

Sebagai Sistem, **saya harus** menolak akses ke URL yang tidak sesuai role, **sehingga** pengguna tidak bisa melakukan bypass dengan mengetik URL secara manual.

Acceptance Criteria:

- Saat user mencoba mengakses URL di luar haknya, sistem wajib memblokir permintaan tersebut.
- Sistem memberikan respon penolakan yang konsisten (Status 403 / Redirect dengan

pesan informasi).

4. Definisi Role & Hak Akses (MVP)

|

Role	Hak Akses (Modul)	Catatan
CS	Manajemen Nasabah, Manajemen Rekening	Modul utama operasional depan.
Teller	Transaksi Setor/Tarik Tunai	Diproteksi jika modul belum siap.
Supervisor	Approval, Monitoring Transaksi	Level otoritas tinggi.
Admin	Manajemen User, Role, & Master Data	Otoritas konfigurasi sistem.

5. Tampilan Antarmuka Pengguna (UI)

- **5.1 Navigasi Berbasis Role:** Sistem merender komponen navigasi secara dinamis berdasarkan *security context*.
- **5.2 Halaman "Akses Ditolak":** Menampilkan pesan: *"Anda tidak memiliki akses ke halaman ini. Silakan hubungi Admin jika Anda merasa ini adalah kesalahan."*

6. Field List & Komponen UI

6.1 Data Kontrol

Data	Tipe	Sumber	Keterangan
role	Enum / String	Session	Diperoleh saat autentikasi.
requestedUrl	String	Request Header	URL yang dituju oleh pengguna.
permissions	List	Config	Pemetaan antara Role dan Endpoint.

6.2 Komponen Sistem

- **Sidebar/Menu:** Komponen UI yang merender item secara kondisional.
- **Guard/Filter Security:** Komponen *server-side* (Interceptor/Filter) yang mengevaluasi setiap *request*.
- **Halaman Penolakan:** *Template* khusus untuk menampilkan error 403.

7. Aturan Bisnis & Validasi

Kondisi	Aturan	Respon Sistem
Belum login	Wajib autentikasi	Redirect ke halaman Login.
Role tidak sesuai	Blokir akses server-side	HTTP 403 / Redirect "Akses Ditolak".
Role null/invalid	Anggap tidak berhak	Tolak akses total.
Manipulasi URL	Cek hak akses per request	Tetap ditolak jika tidak ada izin.

8. Persyaratan Non-Fungsional (NFR)

- **NFR-AUTHZ-001 Keamanan:** *Enforcement* harus terjadi di server. Pembatasan di UI (menyembunyikan menu) hanyalah kosmetik.
- **NFR-AUTHZ-002 Konsistensi:** Respon penolakan harus seragam di seluruh aplikasi.
- **NFR-AUTHZ-003 Audit:** Mencatat setiap percobaan akses ilegal (siapa, kapan, URL

mana).

- **NFR-AUTHZ-004 Maintainability:** Pemetaan akses harus mudah dikonfigurasi tanpa mengubah logika inti.

9. Ketergantungan

- **FR.001 (Autentikasi):** Untuk menyediakan identitas dan role user.
- **Security Framework:** (Contoh: Spring Security) untuk menangani *filter chain*.
- **UI Templating:** Untuk rendering menu dinamis.

10. Isu Terbuka

- Apakah aplikasi akan mendukung *multi-role* (satu user memiliki lebih dari satu jabatan)?
- Penentuan mekanisme penolakan: Apakah menggunakan HTTP 403 mentah atau halaman khusus yang lebih *user-friendly*?

11. Skenario Pengujian (Test Scenarios)

ID Skenario	Nama Skenario	Jenis
TS-AUTHZ-MENU-001	Menu tampil sesuai role (Happy Path)	Functional
TS-AUTHZ-URL-001	Akses URL sesuai role berhasil	Functional
TS-AUTHZ-URL-002	Akses URL di luar otoritas ditolak	Negative
TS-AUTHZ-URL-003	Akses halaman internal tanpa login	Negative
TS-AUTHZ-ERR-001	Konsistensi tampilan pesan error	UI/UX

12. Alur Proses (Flowchart)

